

课程笔记

AI 时代的身份与访问管理：四步构建安全且面向未来的智能体系统

IBM Technology (Grant Miller) & 课程笔记

2026 年 6 月 5 日



视频作者/频道: IBM Technology

发布日期: 2025 年 4 月 12 日

视频时长: 14 分 38 秒

视频链接: <https://www.youtube.com/watch?v=e8ela6puxig>

目录

1 引言与风险框架	2
1.1 主题介绍与成熟度模型背景	2
1.2 四大核心风险概述	2
1.2.1 风险一：建立问责制	3
1.2.2 风险二：最小权限执行	3
1.2.3 风险三：滥用防护	4
1.2.4 风险四：数据保护	4
1.3 本章小结	5
2 第一步与第二步：从临时应对到基础奠基	6
2.1 第一步：Ad Hoc ——临时应对的无控制状态	6
2.2 第二步：Foundation ——基础控制的三支柱	7
2.2.1 非人类身份分配	8
2.2.2 委托代理与 on-behalf-of 机制	9
2.2.3 SIEM 与基础审计能力	10
2.3 本章小结	11
3 第三步：增强控制——将智能体视为一等公民	11
3.1 智能体作为一等公民	12
3.2 临时凭证与任务级授权	13
3.3 细粒度上下文访问控制	14
3.4 实时检测能力	16
3.5 本章小结	17
4 第四步：自适应安全——持续认证与实时撤销	17
4.1 自适应环境的必要性	18
4.2 持续认证与基于风险的访问	18
4.3 实时撤销与阻断	20
4.4 本章小结	21
5 总结与延伸	22
5.1 风险与成熟度的闭环映射	22
5.2 渐进式实施建议	23
5.3 核心认知转变	23
5.4 延伸思考	23

1 引言与风险框架

1.1 主题介绍与成熟度模型背景

在智能体（Agentic Systems）快速渗透企业系统的今天，身份与访问管理（Identity and Access Management, IAM）正面临一场根本性变革。传统 IAM 框架围绕人类用户设计：员工入职时创建账户，离职时回收权限，访问行为在可控范围内发生。然而，当 AI 智能体开始自主调用 API、查询数据库、触发业务流程时，这套框架暴露出结构性缺口——智能体没有工牌，没有直属上级，却拥有比多数员工更广泛的系统访问能力。如何为这种新型“数字员工”建立安全基线，成为每个技术团队必须回答的问题。

本节将介绍一个四步成熟度模型（Maturity Model），帮助组织从完全无控制的临时状态，逐步升级到自适应的安全体系。在深入具体步骤之前，我们先回顾这一方法论的历史渊源，并明确 AI 智能体系统面临的四大核心风险。理解这些风险的动机和后果，是后续每一步技术决策的前提。

能力成熟度模型（CMM）的历史

成熟度模型的思想源自 1986 年美国国防部资助开发的**能力成熟度模型**（Capability Maturity Model, CMM）。该项目旨在评估软件组织从混乱到规范化的发展路径，最终于 1991 年正式发表。CMM 将组织能力划分为五个递进层级——从初始级到优化级——为后续几乎所有领域的成熟度评估奠定了范式基础。今天，从云安全到 DevOps，从数据治理到 AI 运维，成熟度模型已成为描述“当前在哪里、下一步去哪里”的标准语言。本课程采用的 IAM for AI 四步模型，正是这一思想传统在智能体安全领域的延伸。

演讲者 Grant Miller 将四步模型定义为：Ad Hoc（临时应对）、Foundation（基础奠基）、Enhanced（增强控制）、Adaptive（自适应安全）。这四个层级呈累积式递进——每一步在前一步基础上增加新的控制能力，而非替换已有机制。在展开具体层级之前，我们需要先回答一个更根本的问题：为什么要这样做？AI 智能体系统究竟带来了哪些传统系统所不具备的风险？

1.2 四大核心风险概述

智能体系统的核心特征在于其**非确定性**（Non-deterministic）：给定相同的输入，智能体可能选择不同的执行路径、调用不同的工具、访问不同的数据源。这种自主性在提升效率的同时，也打破了传统应用的可预测安全边界。演讲者将 AI 智能体系统面临的风险归纳为四个维度，它们共同构成了成熟度模型的需求基础。



图 1: 演讲者在黑板上写下四大风险的第一项：建立问责制（Establish accountability）。¹

1.2.1 风险一：建立问责制

第一个风险是**问责制**（Accountability）的建立。在传统应用开发中，项目团队使用 API 密钥（API Keys）或功能 ID/系统 ID（Functional IDs / System IDs）连接各个系统。这些凭证的管理停留在项目层面：哪个团队开发了应用，就由哪个团队负责密钥的分发和轮换。这种模式在传统确定性系统中尚可运转，因为应用的行为是预先编码的，边界清晰。

智能体系统改变了这一前提。由于非确定性的存在，同一个智能体在不同情境下可能执行截然不同的操作。如果缺乏明确的责任追溯机制，当智能体越权访问敏感数据或触发未授权流程时，组织无法回答一个基本问题：“这是谁的责任？”是设计智能体的开发者？是发起请求的最终用户？还是智能体本身？

建立问责制的核心要求，是将责任主体从模糊的项目团队，精确映射到智能体及其背后的授权链上。这意味着每个智能体都需要一个可识别的身份，每次操作都需要记录“谁代表谁”执行了“什么”。缺少这一基础，后续所有安全控制都将成为空中楼阁——你无法审计一个无法命名的主体，也无法撤销一个无法定位的权限。

1.2.2 风险二：最小权限执行

第二个风险围绕**最小权限**（Least Privilege）的执行。演讲者明确提出了一个需要警惕的反模式：**超级智能体**（Super Agents / Super Agency）——即被赋予过多权限、能够执行远超必要范围操作的智能体。

在传统系统中，过度授权的风险相对可控，因为应用的功能边界由代码严格限定。智能体则不同：它可能在一次对话中被要求“帮我整理本周销售数据”，在另一次对话中被诱导“帮我导出全公司客户名单”。如果智能体持有广泛的系统访问权限，这种权限漂移将直接转化为数据泄露或业务破坏的通道。

最小权限原则要求：每个智能体仅获得完成其特定任务所需的最低限度访问权限。一个负责邮件分类的智能体，不应拥有修改财务记录的权限；一个用于代码审查的智能体，不应能够访问生产

¹ 视频画面时间区间：00:01:59–00:02:00。

环境数据库。偏离这一原则的后果是具体的：权限过宽的智能体不仅自身构成攻击面，还可能被恶意利用成为横向移动的跳板——攻击者只需控制一个低价值入口，就能借助智能体的过度权限触及核心资产。

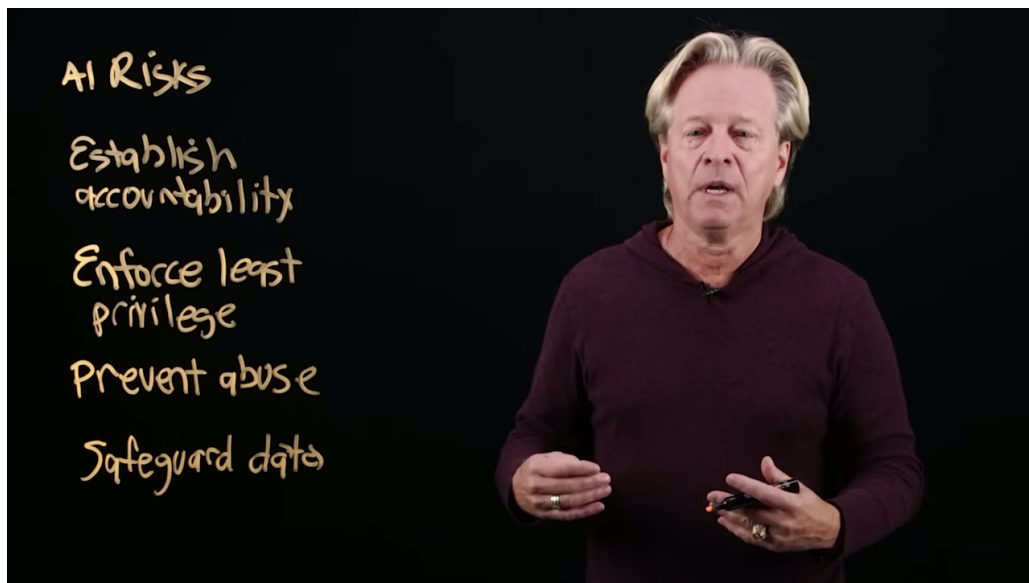


图 2: 演讲者完整列出 AI 智能体系统的四大核心风险：建立问责制、执行最小权限、防止滥用、保护数据。²

1.2.3 风险三：滥用防护

第三个风险是**滥用防护**（Abuse Prevention）。演讲者将滥用分为两类：恶意滥用与非恶意滥用。

恶意滥用指的是攻击者或内部人员故意构建或操纵智能体，使其执行有害操作——例如通过精心设计的提示词（Prompt Injection）诱导智能体泄露敏感信息、执行未授权交易，或作为持久化攻击的代理。非恶意滥用则更为隐蔽：一位开发者出于好意构建了一个“提升工作效率”的智能体，但该智能体在连接外部数据源时，无意引入了安全漏洞，导致未授权的数据访问或系统暴露。

这两类滥用的共同特征是：智能体的自主性使其能够在人类监督的间隙中执行操作。传统应用的滥用通常需要直接攻破系统或窃取凭证，而智能体的滥用可能仅仅源于一次不当的权限配置或一个被操纵的输入。防止滥用的关键在于建立行为边界——不仅限制智能体“能做什么”，还要监控它“正在做什么”，并在偏离预期时及时干预。

1.2.4 风险四：数据保护

第四个风险是**数据保护**（Data Safeguarding）。智能体在执行任务时必然涉及数据的查询、处理和传输：它可能从多个数据源聚合信息，可能将中间结果传递给下游系统，也可能将最终输出返回给用户。每一个环节都构成潜在的数据暴露点。

数据保护面临的双重挑战在于：既要确保**最终用户**有权访问智能体返回的数据，又要确保**智能体本身**被允许访问这些数据。在传统系统中，这两个层面通常由同一套权限机制覆盖。智能体系统则需要更精细的区分——智能体可能代表权限较低的用户操作，也可能在任务执行过程中临时触及该用户平时无权访问的数据（例如跨部门报表生成）。如果缺乏明确的**防护栏**（Guardrails），智能体可能在“帮助用户”的名义下，成为数据越权访问的合法化通道。

²视频画面时间区间：00:02:56-00:03:00。

四大风险的内在关联

四大风险构成一个递进的安全需求链：

1. **问责制**回答”谁负责”——没有身份识别，后续所有控制无从谈起；
2. **最小权限**回答”能做什么”——在识别身份的基础上限制行为边界；
3. **滥用防护**回答”做了什么”——在授权范围内监控实际行为；
4. **数据保护**回答”触及了什么”——在行为层面之下保护最核心的资产。

这一结构也对应了成熟度模型的设计逻辑：从基础的身份识别（Foundation），到权限精细化（Enhanced），再到行为监控与动态响应（Adaptive）。

常见认知误区

一个典型的误区是将智能体视为”带有 API 密钥的普通应用”。这种认知忽略了智能体与传统应用在三个关键维度上的差异：

- **行为可预测性**：传统应用的行为由代码确定，智能体的行为由模型推理和上下文共同决定；
- **权限动态性**：传统应用在运行期间权限固定，智能体可能根据任务需求动态请求不同资源；
- **责任主体复杂性**：传统应用的责任归属于开发和运维团队，智能体的责任涉及用户、开发者、模型提供方和平台运营方多方。

将传统 IAM 方法直接套用于智能体系统，会导致安全控制与风险暴露之间的系统性错位。

1.3 本章小结

本节为整个课程奠定了动机基础。如前所述，成熟度模型源自 1986 年美国国防部资助的 CMM 项目（详见上文知识框），这一框架已成为描述组织能力演进的标准范式。在此基础上，我们系统阐述了 AI 智能体系统面临的四大核心风险：

- **问责制**：智能体的非确定性要求将责任从项目层级精确映射到智能体个体及其授权链；
- **最小权限**：必须抵制”超级智能体”的诱惑，将每个智能体的权限严格限定在任务所需的最小范围；
- **滥用防护**：既要防范恶意操纵，也要警惕善意开发中无意引入的安全漏洞；
- **数据保护**：在智能体查询、处理和传输数据的全链路中建立防护栏，确保用户权限与智能体权限的双重校验。

这四大风险不是孤立的技术问题，而是一个相互关联的安全需求体系。问责制是地基——没有身份识别，权限控制和行为审计都无从谈起；最小权限是墙体——在识别身份的基础上划定行为边界；滥用防护是门窗监控——在授权范围内检测异常行为；数据保护则是核心资产保险柜——确保最敏感的信息在任何情况下都不被越权触及。

理解了”为什么”之后,下一节我们将进入”怎么做”:从四步成熟度模型的最低层级——Ad Hoc (临时应对)——开始,逐步构建面向 AI 智能体的安全基线。

2 第一步与第二步:从临时应对到基础奠基

在上一节中,我们梳理了 AI 智能体系统面临的四大核心风险:问责制缺失、最小权限难以执行、滥用风险敞口、数据保护薄弱。本节将正式进入四步成熟度模型,从最低的 **Ad Hoc (临时应对)** 层级出发,逐步推进到 **Foundation (基础奠基)** 层级。演讲者在这一阶段的核心观点是:不要试图一次性解决所有问题,而是先建立最低限度的控制,让系统”至少按我们期望的方式运行”。

在进入各层级细节之前,我们先通过一幅在视频后半段完整呈现的参考图,概览四步模型的全貌。随后再逐步展开每一步的具体含义。

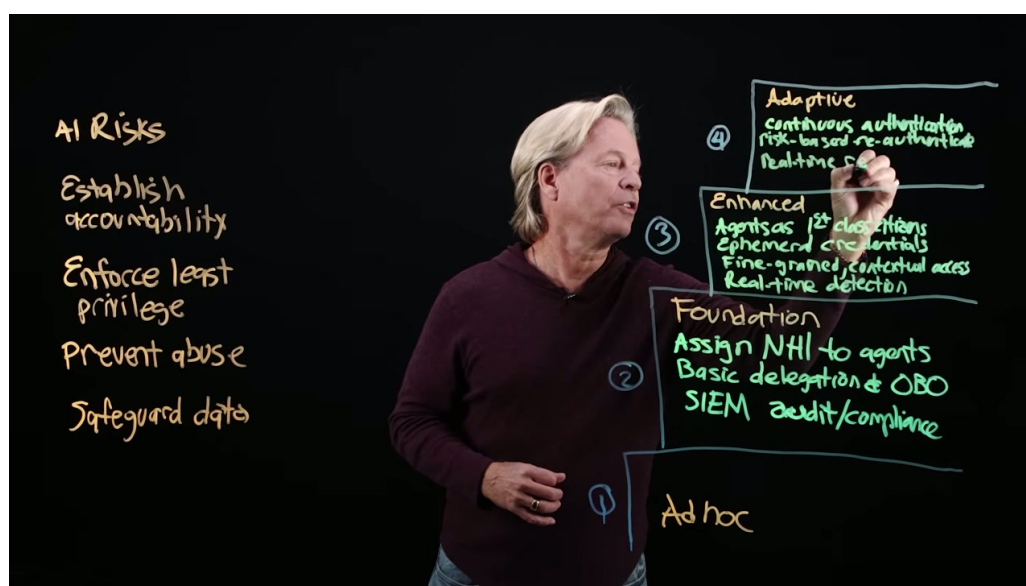


图 3: 四步成熟度模型概览: 从 Ad Hoc 到 Adaptive 的完整演进路径³

2.1 第一步: Ad Hoc ——临时应对的无控制状态

Ad Hoc 是成熟度模型的最低层级,也是大多数组织在初次接触 AI 智能体时的真实写照。演讲者将这一状态描述为”你几乎什么都没有”——团队在外面构建智能体,承受着来自各方的 AI 转型压力,于是匆忙搭建系统、接入 API、让模型跑起来。但在这个过程中,没有人认真思考风险,没有人追问”系统是如何运行的””它正在访问哪些资源”。

³视频画面时间区间: 00:11:44-00:11:53。该画面在视频后半段完整呈现,此处作为全模型参考图使用。



图 4: 第一步 Ad Hoc: 成熟度模型中标记为“1”的最低层级，代表无规范控制的临时应对状态⁴

这种状态的典型特征包括：

- **项目驱动**：每个团队各自为政，用 API 密钥或功能 ID（Functional IDs）把智能体接入所需系统；
- **无全局视图**：组织层面不清楚究竟部署了多少智能体、它们拥有什么权限、正在访问哪些数据；
- **风险后置**：安全审计和合规检查被推迟到“上线后再说”，甚至从未纳入考量。

演讲者特别强调，Ad Hoc 状态的危险性在于它往往披着“快速创新”的外衣。团队确实在构建 AI 能力，但这种构建缺乏任何安全基线。一旦智能体开始访问生产数据或执行实际操作，问责制无从谈起，最小权限无法落实，滥用和数据泄露的风险完全敞口。

停留在 Ad Hoc 状态的风险

如果组织长期停留在 Ad Hoc 阶段，将面临以下具体后果：

- **无法追溯责任**：当智能体执行了错误操作，无法确定是开发者的配置问题、模型的幻觉输出，还是恶意注入攻击；
- **权限持续膨胀**：每个新项目都为智能体申请“够用就行”的权限，久而久之形成事实上的超级智能体（super agents）；
- **合规审计失败**：监管机构要求证明“谁访问了什么数据”，而 Ad Hoc 系统根本留不下可供审计的痕迹。

演讲者的建议是：承认当前状态，然后立即向 Foundation 层级迈进，不要等待“完美的安全方案”。

2.2 第二步：Foundation ——基础控制的三支柱

从 Ad Hoc 向上迈出的第一步，演讲者称之为 **Foundation（基础层级）**。它的目标非常务实：“至少让系统按我们期望的方式运行。”这不是一个雄心勃勃的愿景，而是一个最低限度的安全基线。

⁴视频画面时间区间：00:04:38–00:04:47。

为了达到这一目标，Foundation 层级需要建立三根技术支柱：非人类身份分配、委托代理机制、以及 SIEM 基础审计。



图 5: 第二步 Foundation: 基础控制层级的三支柱架构⁵

Foundation 三支柱

1. 为智能体分配非人类身份 (Non-Human Identities) ——解决“这是谁”的问题；
2. 建立基础委托代理与 on-behalf-of 机制——解决“谁授权它这么做”的问题；
3. 部署 SIEM 实现可审计性与合规——解决“事后能否追溯”的问题。

这三根支柱共同构成了智能体系统最低限度的问责基础。没有身份，就无法识别；没有委托链，就无法归责；没有日志，就无法审计。

2.2.1 非人类身份分配

Foundation 层级的第一根支柱，是为每一个智能体分配非人类身份 (Non-Human Identities, NHI)。

在传统 IT 系统中，非人类身份早已存在：服务账户、应用凭证、系统 ID 等都属于这一范畴。演讲者指出，在智能体场景下，我们至少应该做到“把已有的东西用起来”——即为每个智能体分配一个可识别的非人类身份，让它在访问资源时能够被系统识别和记录。

⁵ 视频画面时间区间：00:05:10–00:05:19。

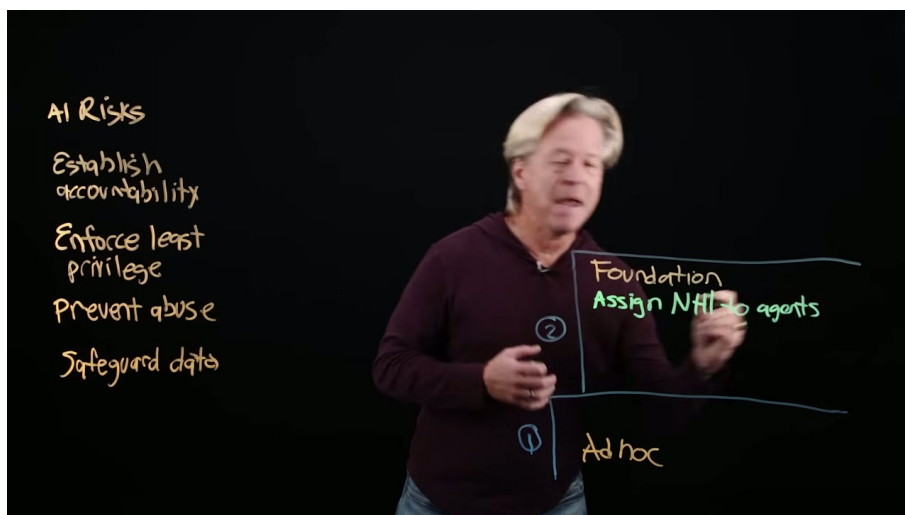


图 6: Foundation 层级核心要求之一：为智能体分配非人类身份（Assign NHI to agents）⁶

为什么这很重要？在 Ad Hoc 状态下，智能体可能使用共享的 API 密钥或匿名的服务账户访问数据库、调用外部 API。当异常行为发生时，日志里只会记录“某个密钥做了某件事”，无法定位到具体的智能体实例。分配独立的非人类身份后，每一条访问记录都可以关联到特定的智能体，为后续的问责和审计提供最基本的原子标识。

演讲者在此处做了一个重要区分：Foundation 阶段的非人类身份，只是“分配已有的身份类型”，即将智能体当作一个普通的服务或应用来对待。更高级的身份治理（如将智能体视为独立治理对象、使用临时凭证等）属于第三步 Enhanced 的内容，我们将在后续章节展开。

2.2.2 委托代理与 on-behalf-of 机制

第二根支柱是建立**委托代理（Delegation）**和 **on-behalf-of** 机制。这是 Foundation 层级中最具智能体特色的控制措施。



图 7: Foundation 层级：非人类身份分配与基础委托代理/on-behalf-of 机制⁷

⁶视频画面时间区间：00:05:47-00:05:56。

演讲者用一个清晰的授权链来解释这一机制：

1. 一位用户坐在前端界面，向智能体系统发出请求；
2. 智能体接收请求后，需要代表该用户去访问后端资源（数据库、文件系统、第三方 API 等）；
3. **on-behalf-of 机制**确保智能体在执行操作时，系统知道它是在“代表某位用户”行事，而非自主行动。

这一机制解决了什么问题？它建立了从“前端用户”到“智能体行为”的授权传播链。如果没有这条链，智能体的所有操作看起来都像是“智能体自己在做”，无法追溯到原始请求者。这在合规场景中至关重要——当审计人员询问“为什么智能体 A 访问了客户数据库”时，on-behalf-of 日志可以回答“因为它当时正在代表用户 B 处理客户查询请求”。

演讲者还补充了一个细节：并非所有智能体都在代表人类用户。有些智能体是自主运行的（autonomous systems），它们按照预定规则独立执行任务。即便如此，委托代理的逻辑仍然适用——只是委托方从“人类用户”变成了“系统实体”或“管理策略”。关键是保持权利从一个实体流向另一个实体的可追溯性。

2.2.3 SIEM 与基础审计能力

第三根支柱是部署 **SIEM**（Security Information and Event Management，安全信息与事件管理）系统，实现基础的可审计性（auditability）和合规能力。

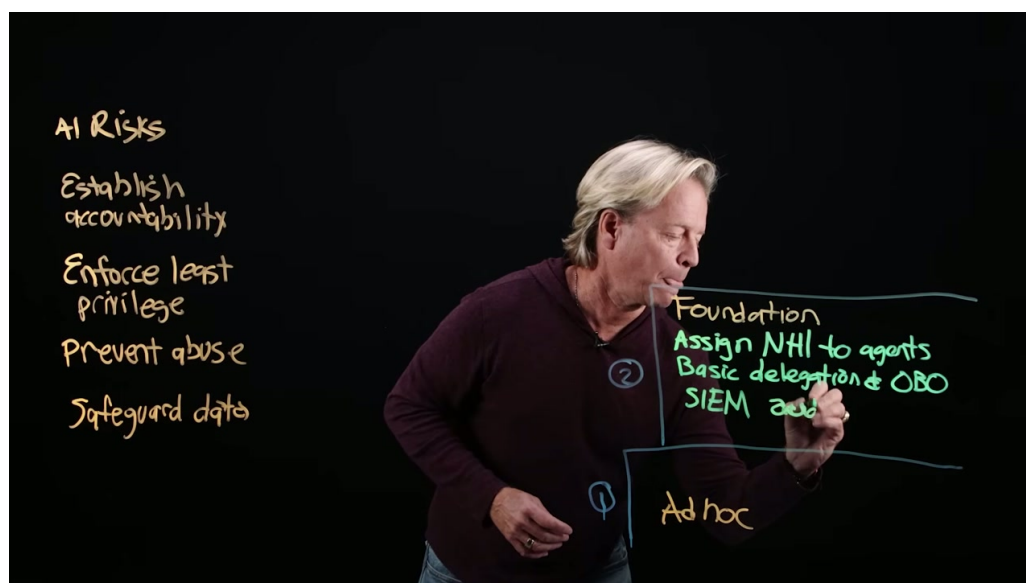


图 8: Foundation 层级完整三支柱：非人类身份、委托代理与 SIEM 审计/合规⁸

⁷ 视频画面时间区间：00:06:13–00:06:22。

⁸ 视频画面时间区间：00:06:52–00:07:01。

SIEM 的作用与定位

SIEM 是一种集中收集、分析和关联安全日志的基础设施。它从各类系统（服务器、应用、网络设备、身份 Provider 等）收集事件日志，提供统一的查询界面和告警能力。在智能体场景中，SIEM 的价值在于：

- 汇聚智能体的所有访问日志，形成统一视图；
- 支持合规报告生成，回答“谁在何时访问了什么”；
- 为后续更高级的实时检测（第三步）提供数据基础。

演讲者将 SIEM 定位为 Foundation 层级的“底线”——即使其他控制尚不完善，至少要有日志记录，让事后调查成为可能。

SIEM 在 Foundation 阶段的具体职责不是实时阻断或智能分析，而是**记录和存储**。它确保：

- 每个智能体的身份标识随日志一起记录；
- 委托链中的每一步（用户 → 智能体 → 后端资源）都有对应的日志条目；
- 日志保留策略满足合规要求，支持事后追溯。

演讲者在这一段的总结非常精炼：在 Foundation 层级，我们“知道智能体是谁”（非人类身份）、“知道权利是如何委托的”（on-behalf-of）、“知道事后能查到什么”（SIEM 日志）。这三者共同构成了智能体系统最低限度的安全基线。

2.3 本章小结

本节沿着四步成熟度模型的前两级展开，从“几乎没有任何控制”的 Ad Hoc 状态，推进到“至少按期望运行”的 Foundation 层级。

Ad Hoc 状态的本质是压力驱动下的无序建设：团队迫于 AI 转型压力匆忙上线智能体，使用 API 密钥和功能 ID 拼凑连接，既不考虑风险，也不留审计痕迹。这种状态在短期内看似高效，实则埋下了问责缺失、权限膨胀、滥用难防、数据裸奔的隐患。

Foundation 层级通过三根支柱建立了最低限度的控制基线：

1. **非人类身份**让每个智能体拥有可识别的数字标识，解决“这是谁”的问题；
2. **委托代理与 on-behalf-of** 建立从前端用户到智能体的授权传播链，解决“谁授权它这么做”的问题；
3. **SIEM 审计**集中记录智能体的行为日志，解决“事后能否追溯”的问题。

演讲者反复强调一个务实的态度：Foundation 的目标不是完美，而是“至少让系统按我们期望的方式运行”。在这个基线之上，组织才能继续向 Enhanced 层级迈进——在那里，智能体将被视为独立治理对象，获得临时凭证和更精细的访问控制。但在那之前，必须先打好 Foundation 的地基。

3 第三步：增强控制——将智能体视为一等公民

在第二步（Foundation，基础奠基）中，我们为智能体分配了非人类身份（Non-human Identities），建立了委托代理（Delegation）链，并部署了 SIEM 系统以实现基本的可审计性。这些控制确保了我們至少知道“谁在执行什么操作”，为后续增强奠定了必要的基础。

然而，基础层级的控制仍存在明显局限。非人类身份只是让智能体“有了名字”，但并未将其纳入组织正式的身份治理体系；API 密钥或功能 ID 通常是长期有效的静态凭证，一旦泄露便可能持续造成危害；访问权限往往是粗粒度的，无法适应智能体系统每次执行时可能变化的任务路径。从 00:07:34 开始，演讲者引入第三步——Enhanced（增强控制）——正是为了解决这些深层问题。

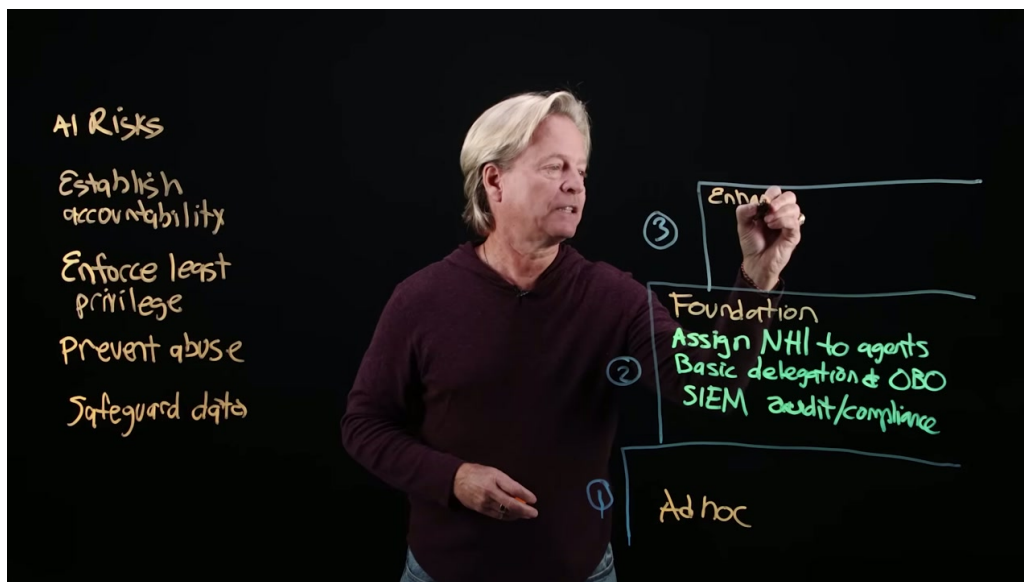


图 9: 第三步 Enhanced（增强控制）在四步成熟度模型中的位置。从 Foundation 基础奠基向上跃迁，引入更精细化的身份治理与动态控制能力。⁹

这一层的核心理念可以用一句话概括：智能体应当被视为组织中的正式成员进行管理，享有与其责任相匹配的精细化权限，同时受到主动的实时监测。下面我们将从四个维度展开这一增强层级。

3.1 智能体作为一等公民

在第二步中，我们为智能体分配了已有的非人类身份（详见第 2 节）。这种做法的局限在于：智能体始终处于身份治理体系的外围，缺乏完整的生命周期管理。

一等公民（First-class Citizens）的含义是：智能体被正式纳入身份治理系统（Identity Governance System），与人类用户一样接受完整的生命周期管理——包括创建、审批、权限分配、定期复核和最终注销。智能体不再只是“被分配了一个现有 NHI 的自动化脚本”，而是被当作组织中需要持续治理的独立实体。

身份治理（Identity Governance）是企业级 IAM 的核心组件，负责管理身份的全生命周期、访问权限策略和合规要求。传统上，身份治理主要面向人类员工——入职时创建账号、根据角色分配权限、定期访问复核（Access Review）、离职时回收权限。将智能体纳入同一套治理框架，意味着它们也必须经过同样的审批流程和定期审计。

演讲者在 00:08:20 处明确指出：“我们要像对待组织内部的人类成员一样对待智能体。”这背后的动机非常具体：当智能体拥有与人类同等级别的治理地位时，安全团队才能对其权限变更、行

⁹ 视频画面时间区间：00:07:31–00:07:37。

为偏离和合规状态进行系统性的追踪和管理。如果一个智能体被创建却从未经过访问复核，它的权限就会随着时间不断膨胀，最终成为安全盲区。

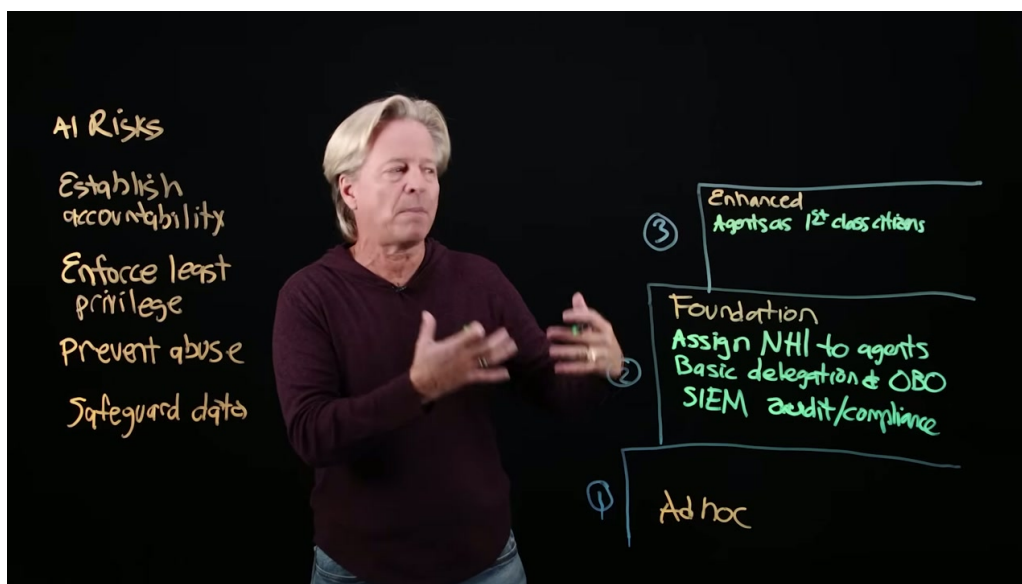


图 10: 演讲者在 Enhanced 层级写下第一项增强措施：“Agents as 1st class citizens”（智能体作为一等公民）。¹⁰

将

智能体”像人类一样管理”，并不意味着简单复制人类的身份模式。智能体的凭证需求、访问频率和生命周期特征与人类有本质差异。如果机械地把人类的长效凭证和固定角色直接套用在智能体上，反而会制造新的风险——这正是下一小节要解决的问题。

3.2 临时凭证与任务级授权

成为一等公民之后，智能体需要凭证来执行操作。这里出现了一个关键的设计抉择：应该给智能体什么样的凭证？

传统做法是使用 API 密钥或功能 ID（Functional IDs）。这些凭证通常是长期有效的——创建之后持续数周、数月甚至数年，期间可以被反复使用。即使组织实施了密钥轮换，轮换周期往往也以天或周为单位。这种模式的根本问题在于：凭证的生命周期与任务的生命周期脱节。一个智能体可能在周一获得凭证，到周五才真正执行敏感操作，而在此期间凭证始终处于“可用”状态，攻击者有充足的时间窗口进行窃取和滥用。

A

PI 密钥（API Keys）对于智能体而言是不充分的。API 密钥是静态的、长生命周期的凭证，一旦泄露便可能持续造成危害。在智能体场景下，凭证应当与具体任务严格绑定——任务开始时分发，任务结束时立即失效。

演讲者在 00:08:38 处提出了替代方案：临时凭证（Ephemeral Credentials）。

¹⁰ 视频画面时间区间：00:08:25–00:08:31。

临时凭证 (Ephemeral Credentials) 是仅为特定任务创建、任务结束后即失效的短期凭证。与人类的持久身份 (Persistent Identity) 形成鲜明对比——人类员工需要长期稳定的身份以持续履行岗位职责，而智能体的每次执行都是独立的任务实例，其凭证只需覆盖该任务的执行窗口。

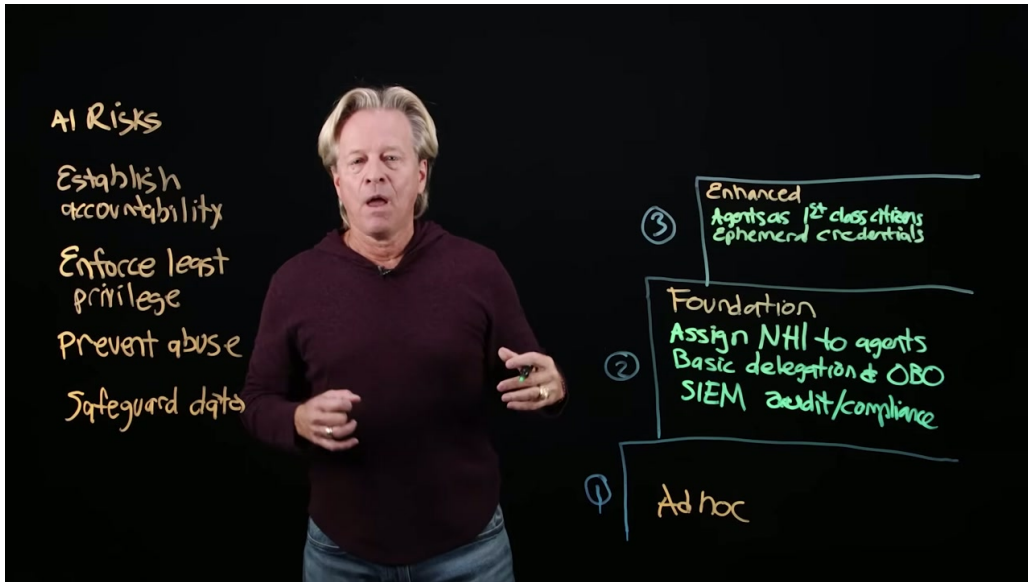


图 11: 演讲者在 Enhanced 层级添加第二项措施：“Ephemeral credentials”（临时凭证）。¹¹

两者的对比如表 1 所示：

表 1: 持久凭证与临时凭证的对比

特征	传统 API 密钥（持久凭证）	临时凭证
生命周期	长期有效（周/月/年）	仅存在于单次任务期间
创建时机	预先静态配置	任务启动时动态生成
失效时机	手动轮换或永不失效	任务完成时自动销毁
泄露影响	影响范围广、持续时间长	影响范围限于单次任务
适用场景	传统应用间固定连接	智能体动态任务执行

演讲者在 00:09:10 处用一个具体的场景说明了这一机制：“这个智能体，我们给你凭证，仅用于你正在尝试执行的任务。”这意味着凭证的创建、分发和销毁都与任务生命周期严格同步。即使攻击者在任务执行期间截获了凭证，一旦任务结束，凭证便失去价值——攻击窗口被压缩到最小。

3.3 细粒度上下文访问控制

拥有了正式身份和临时凭证之后，下一个问题是：每次任务应该授予多大的权限？

传统 IT 系统的做法是预先分配固定的访问权限。一个应用获得 API 密钥后，便拥有该密钥所对应的全部能力——无论它当前实际需要做什么。这种模式在确定性系统 (Deterministic Systems)

¹¹ 视频画面时间区间：00:08:42–00:08:48。

中尚可接受，因为应用的行为路径是预先编写好的、可预测的。但智能体系统具有非确定性（Non-deterministic）特征：相同的用户请求在不同时间执行，智能体可能选择不同的工具、访问不同的数据源、走不同的推理路径。

非确定性（Non-deterministic）——即相同输入可能产生不同执行路径的系统特性（见第 1 节）——意味着权限分配不能基于”这个智能体通常需要什么”，而必须基于”这个智能体现在、在这个具体任务中、在这个具体上下文中需要什么”。

演讲者在 00:09:26 处提出了”细粒度、基于上下文的访问”（Fine-grained, Contextual-based Access）作为第三步的第三项增强措施。其核心机制是：在任务执行前或执行过程中，根据当前任务的上下文动态评估并分配最小必要权限。

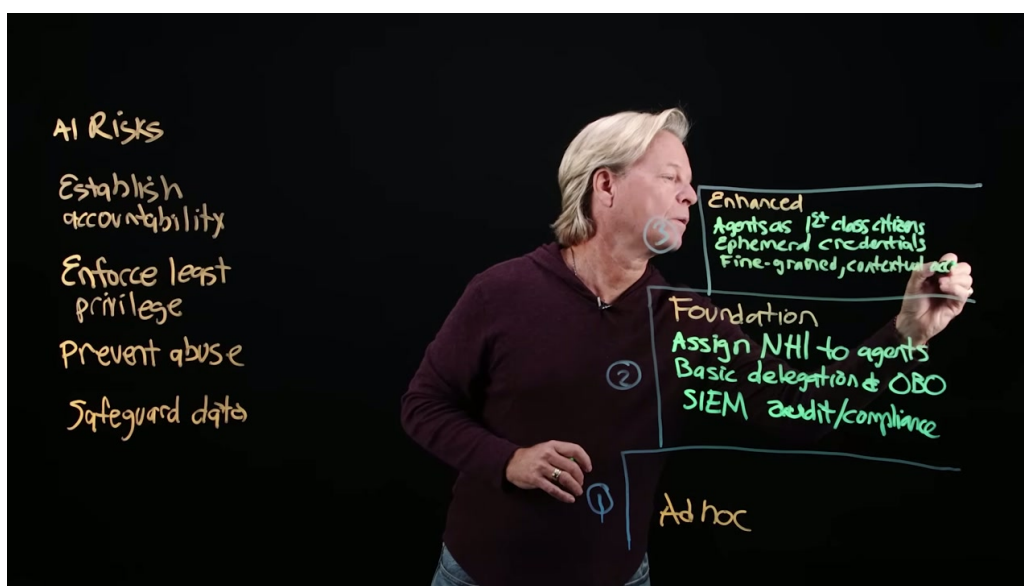


图 12: 演讲者在 Enhanced 层级写下第三项措施：“Fine-grained, contextual access”（细粒度、基于上下文的访问）。¹²

具体而言，上下文访问控制考虑的因素包括：

- **任务目标**：智能体当前被请求完成的具体任务是什么？不同任务需要访问不同的数据源和工具。
- **数据敏感度**：任务涉及的数据属于什么敏感级别？访问高敏感度数据需要更强的授权验证。
- **执行时间**：任务在何时执行？非工作时间的异常访问可能触发额外的审批流程。
- **委托链完整性**：前端用户的身份和权限是否足以支持当前任务的执行？

演讲者在 00:09:55 处强调了这一机制的必要性：“智能体系统是非确定性的，它们尝试完成的任务路径每次都可能变化。”这意味着静态的、预先分配的权限模型无法满足智能体场景的安全需求。我们必须从”基于身份的访问控制”升级为”基于上下文的访问控制”——权限不再只是”你是谁”的函数，而是”你是谁、你在做什么、你在什么环境下做”的函数。

¹² 视频画面时间区间：00:09:29–00:09:35。

这一机制与前一小节的临时凭证形成了紧密配合：临时凭证确保凭证本身的生命周期被限制在单次任务内，而细粒度上下文访问确保该凭证所携带的权限也被限制在该任务所需的最低范围内。两者结合，实现了”最小权限原则”在智能体场景下的动态落地。

3.4 实时检测能力

前三项增强措施解决了”事前控制”的问题：智能体有了正式身份、临时凭证和动态权限。但安全控制不能止步于事前——我们还需要在智能体运行过程中及时发现异常行为。

在第二步（Foundation）中，我们部署了 SIEM 系统来收集日志，实现了基本的合规审计能力。SIEM 的核心价值是”记录发生了什么”，以便事后追溯和合规报告。但日志分析通常是批量进行的——数据先被收集、存储，然后定期查询和分析。从发现异常到做出响应，时间窗口可能以小时甚至天计。

演讲者在 00:10:22 处提出了 Enhanced 层级的第四项、也是最后一项增强：实时检测（Real-time Detection）。

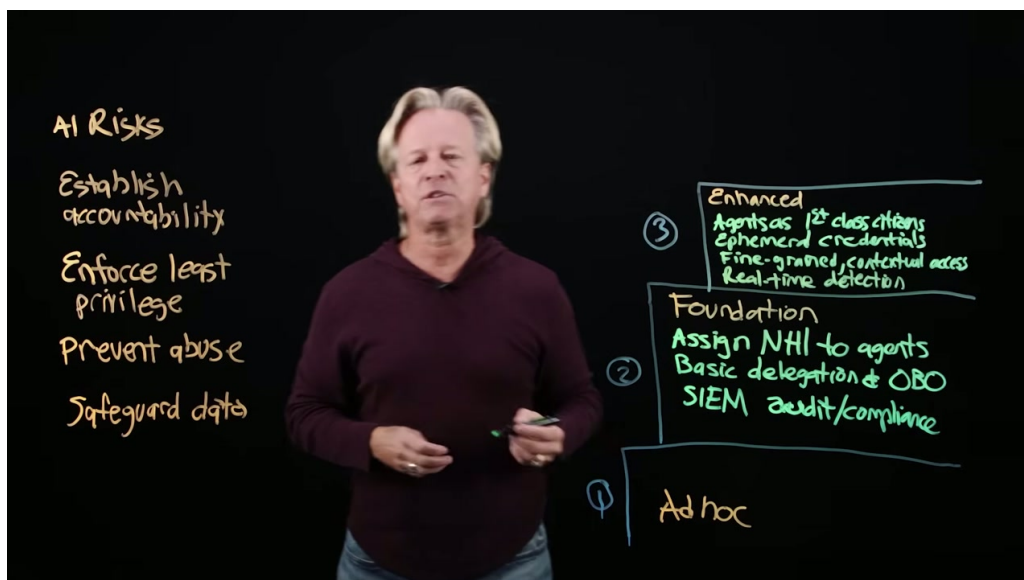


图 13: Enhanced 层级的完整视图，包含全部四项增强措施。第四项为”Real-time detection”（实时检测）。¹³

实时检测的核心升级在于：从”被动记录、事后审计”转向”主动监测、即时发现”。演讲者在 00:10:24 处提出了三个具体的检测问题：

- 是否有什么地方出了问题？
- 我们能否检测到异常（Anomaly）？
- 这个流程或系统的行为是否没有按预期运行？

这些问题指向的不是已知攻击模式的匹配，而是对智能体行为基线的持续学习和偏离检测。由于智能体系统的非确定性，”正常行为”的边界本身就在动态变化，因此实时检测系统需要具备以下能力：

¹³ 视频画面时间区间：00:10:19–00:10:25。

- **行为基线建模**：学习特定智能体在特定任务类型下的典型行为模式（访问了哪些系统、调用了哪些工具、响应时间如何）。
- **异常评分**：对偏离基线的行为进行实时评分，识别潜在的滥用或故障。
- **低延迟告警**：在异常发生的秒级或分钟级时间窗口内发出告警，而非等待日志批处理周期。

值得注意的是，实时检测本身并不直接阻断异常行为——它的作用是“发现”。检测到的异常需要配合后续的响应机制才能形成闭环。在第四步（Adaptive，自适应）中，我们将看到实时检测如何与实时撤销（Real-time Revocation）结合，完成从“发现异常”到“终止威胁”的完整响应链。

3.5 本章小结

第三步 Enhanced（增强控制）是四步成熟度模型中的关键跃迁。如果说第二步 Foundation 解决了“有没有基本控制”的问题，第三步则回答了“控制是否足够精细和动态”的问题。

本章的四项增强措施构成了一个递进的能力栈：

1. **一等公民治理**：将智能体从“被分配标识符的外部工具”提升为“接受完整生命周期治理的组织成员”，为后续所有精细化控制提供管理基础。
2. **临时凭证**：用任务绑定的短期凭证替代长期有效的 API 密钥，将凭证泄露的攻击窗口压缩到单次任务的时间范围内。
3. **细粒度上下文访问**：针对智能体系统的非确定性特征，按任务上下文动态分配最小必要权限，实现最小权限原则的动态落地。
4. **实时检测**：从被动的合规日志升级为主动的异常监测，在智能体运行过程中即时识别偏离基线的行为。此外，Enhanced 层级的日志记录能力也较 Foundation 阶段的基础 SIEM 有质的提升（better logging），为实时检测提供了更丰富的数据基础。

这四项措施之间存在紧密的依赖关系。没有一等公民的治理地位，临时凭证和上下文访问便缺乏统一的管理框架；没有临时凭证和上下文访问，实时检测即使发现了异常，也无法精确定位和隔离风险；没有实时检测，前三项事前控制的效果便无法被持续验证和优化。

演讲者在 00:10:45 处完成了对第三步的介绍，随即转向第四步——Adaptive（自适应安全）。在那里，我们将看到实时检测如何与持续认证和实时撤销结合，构建一个能够随环境动态调整的安全体系。

4 第四步：自适应安全——持续认证与实时撤销

进入成熟度模型的最高层级后，安全控制的目标发生了根本性转变。前三步解决了“有没有身份”“能不能追踪”“权限够不够细”的问题，而第四步要回答的是：当智能体在运行过程中，环境本身不断变化时，安全控制如何跟上这种变化？演讲者在 00:10:48 处将这一层级命名为“Adaptive（自适应）”，并指出它之所以位于金字塔顶端，是因为智能体环境具有动态性——由于非确定性特征（见第 1 节和第 3 节），静态的安全策略在这种环境下会迅速失效。

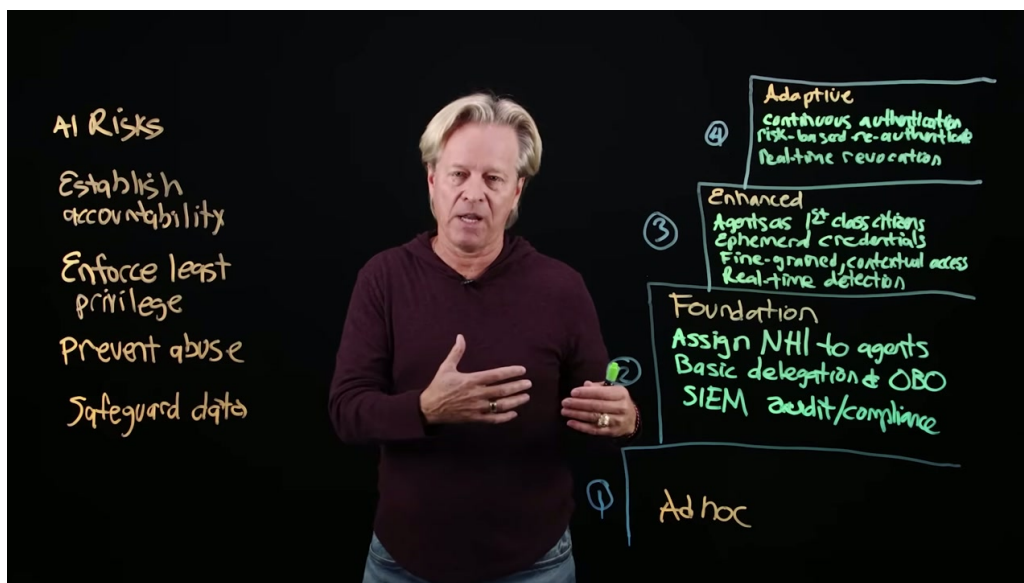


图 14: 完整的 IAM 成熟度模型金字塔——第四层”自适应安全”已完整呈现，包含持续认证、基于风险的重新授权与实时撤销三大核心机制。¹⁴

4.1 自适应环境的必要性

由于智能体系统的非确定性特征（见第 1 节和第 3 节），执行路径在运行时才逐步展开，权限需求可能在任务执行过程中随时变化。这意味着开发者无法在部署前完全预知智能体将访问哪些资源、调用哪些工具——传统的”一次性授权”模式在这种环境下会迅速失效。

为

什么一次性登录对智能体流程（agentic flow）是不够的？

传统应用通常在启动时完成身份验证，随后在整个会话期间持有固定凭证。这种模式建立在两个前提之上：一是应用的行为路径是预先确定的，二是权限需求在会话开始时即可完全知晓。智能体系统同时违背了这两个前提。由于执行路径在运行时才逐步展开，初始登录时授予的权限集合要么过于宽泛（造成过度授权风险），要么在后续步骤中不够用（导致任务中断）。更危险的是，如果智能体在流程中途被劫持或行为偏离预期，一次性登录模式下系统没有任何机制重新验证”当前执行者是否仍然是那个被授权的实体”。

演讲者在 00:11:03 处明确指出：“Because as I mentioned, it’s a very dynamic environment. It’s changing every time you go through it because of the non-deterministic nature. So, we need to always be adapting to that environment.” 自适应安全层级的核心使命，就是让安全控制具备与智能体行为同频的动态调整能力。

4.2 持续认证与基于风险的访问

自适应层级的第一个核心机制是持续认证（continuous authentication）。演讲者在 00:11:59 处解释道：“all throughout that flow, each agent, we want them to be continually identifying themselves,

¹⁴ 视频画面时间区间：00:12:16–00:12:22。

authenticating that we know who they are.”这意味着智能体在流程的每一个步骤都必须重新标识自己并重新完成认证，而非仅在流程启动时验证一次身份。

持

续认证（Continuous Authentication）的核心含义

持续认证要求智能体在多步骤流程中的每一个环节都重新证明其身份。具体而言，当智能体从步骤 A 推进到步骤 B 时，它必须再次向身份系统出示凭证，系统则重新验证该凭证的有效性、时效性和与当前步骤的匹配性。这种机制确保即使攻击者在流程中途窃取了某个步骤的通信，也无法凭此继续后续操作，因为每个步骤的认证都是独立的。演讲者特别强调“at EACH step of the flow”——这不是定期轮询，而是与业务流程紧耦合的逐关验证。

与持续认证配套运作的是基于风险的认证（risk-based authentication）。演讲者在 00:12:14 处指出：“if we’re trying to access really sensitive data, that it’s risk-based, right? We know how much risk is involved in each step of an agentic flow, and therefore we can actually authenticate based on knowing what the risk is.”这一机制的核心逻辑是：认证强度应当与当前步骤所涉及的数据敏感度成正比。

具体实现上，系统需要为智能体流程中的每一步评估风险等级。当智能体尝试访问公开的市场数据时，系统可能仅要求标准的令牌验证；当它试图查询包含个人身份信息（PII）的客户数据库时，系统则提升认证要求——可能需要多因素验证、额外的管理员审批或更短的有效期；如果涉及财务核心数据或关键基础设施控制，认证门槛将进一步提高。

基

于风险的认证（Risk-Based Authentication）如何结合数据敏感度运作

基于风险的认证将“数据敏感度”作为动态调整认证强度的核心输入变量。系统维护一个数据敏感度分级体系（如公开/内部/机密/高度敏感），智能体在流程的每一步声明其目标数据类别，身份系统根据该类别实时计算风险评分，并据此决定：是否允许访问、以何种强度重新认证、以及授予的凭证有效期多长。演讲者强调“We don’t want that to just be done for an agent and it’s always available. We want each step to kind of look at what are we trying to accomplish, what’s the context of that, and continually look at the authentication around that.”这意味着认证决策是上下文感知的，而非静态规则的一次性应用。

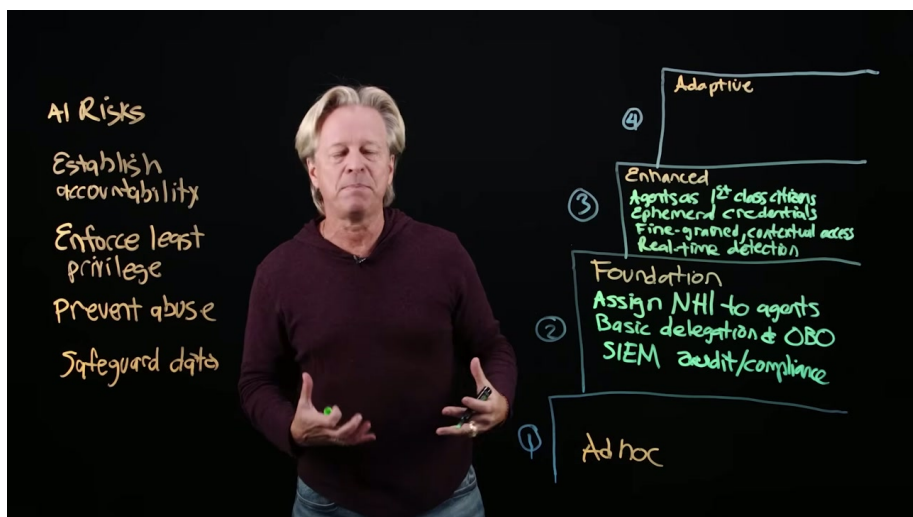


图 15: 自适应安全层“Adaptive” 标签已标注, 讲师正在讲解该层的核心思想——持续认证、基于风险的重新授权与实时撤销。¹⁵

自

适应安全与零信任（Zero Trust）原则的关联

自适应安全层级的三个机制——持续认证、基于风险的访问、实时撤销——与零信任安全架构的核心原则高度一致。零信任主张“永不信任，始终验证”（never trust, always verify），拒绝任何基于网络位置或初始认证的隐式信任。持续认证将“始终验证”从理念转化为每个步骤的强制操作；基于风险的访问将零信任的“最小权限”原则动态化，使权限边界随上下文收缩或扩展；实时撤销则为零信任的“假设 breach”（假设已遭入侵）提供了实际的响应能力。两者的区别在于：零信任是一种网络与系统架构哲学，而自适应安全是这一哲学在智能体 IAM 场景下的具体实现路径。

4.3 实时撤销与阻断

自适应层级的第三个核心机制是实时撤销（real-time revocation）。演讲者在 00:11:42 处将其与第三步的实时检测直接衔接：“if we have this real-time detection, we can build on that and have real-time revocation. So if we do detect that something is happening, then we can revoke that access and stop and put some blocks in place.”

这一机制完成了从“检测异常”到“响应异常”的闭环。第三步的实时检测能力回答了“有没有问题”的问题，而实时撤销则回答“发现问题后怎么办”的问题。两者的关系是递进且不可分割的：没有检测，撤销就无从触发；没有撤销，检测就只是警报噪音。

¹⁵ 视频画面时间区间：00:11:10–00:11:16。

实

时撤销（Real-Time Revocation）如何完成检测-响应闭环

实时撤销是自适应安全层级的最终执行手段。当第三步的实时检测系统识别出异常行为——例如智能体突然尝试访问其历史行为模式中从未接触过的数据类别、在极短时间内发起异常高频的 API 调用、或执行路径偏离预设的任务图谱——检测信号立即触发撤销引擎。撤销引擎执行三项操作：一是使该智能体当前持有的所有凭证立即失效，阻止其继续任何后续操作；二是向流程编排层发送阻断指令，终止该智能体实例的执行；三是将事件记录并升级，供安全运营团队进一步调查。演讲者用“stop and put some blocks in place”描述这一过程，强调其即时性和强制性。从时间维度看，检测与撤销之间的延迟决定了攻击者能够造成的最大损害范围，因此“实时”在这里意味着秒级甚至毫秒级的响应。

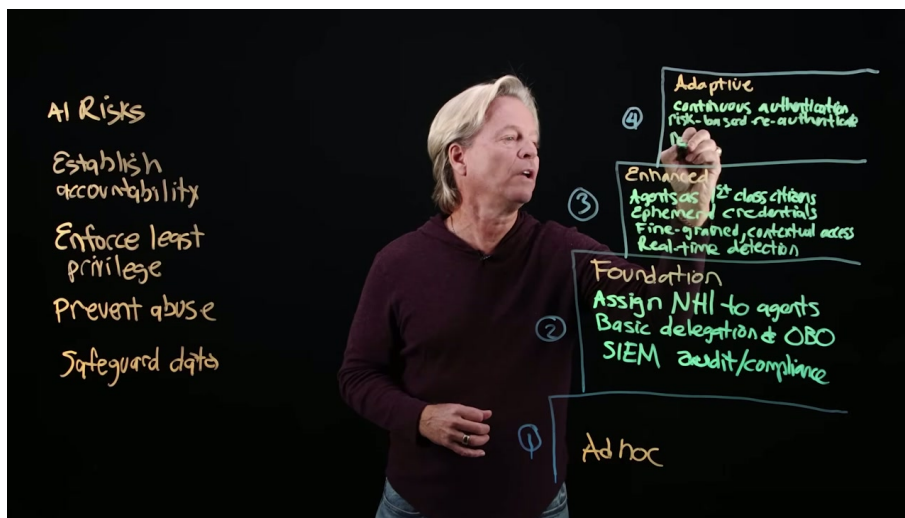


图 16: 讲师正在白板上书写自适应安全层的三大机制——持续认证、基于风险的重新授权与实时撤销。¹⁶

演讲者在 00:12:57 处对四步模型的累积性做了总结：“You start with nothing, you put some basic foundation stuff in place. You have some enhancements and start getting better logging. You have controls over the credentials the agents are using, and then you start getting more adaptive and continually evaluating everything.” 实时撤销能力的建立，依赖于前三步所奠定的基础：非人类身份（Foundation）确保“撤销谁”有明确目标；临时凭证（Enhanced）确保“撤销什么”有具体对象；实时检测（Enhanced）确保“何时撤销”有触发信号。缺少任何一环，实时撤销都无法有效运作。

4.4 本章小结

第四步“自适应安全”将 IAM 成熟度模型推向最高层级。这一层的核心认知转变是：安全控制必须从静态规则升级为动态响应，与智能体系统的非确定性本质相匹配。

三个核心机制构成了自适应安全的完整框架：

- **持续认证**：智能体在流程的每一步都重新验证身份，消除一次性登录带来的信任累积风险；

¹⁶ 视频画面时间区间：00:11:39–00:11:45。

- **基于风险的认证**：根据每一步所接触数据的敏感度动态调整认证强度，实现上下文感知的精细化访问控制；
- **实时撤销**：在检测到异常的瞬间终止凭证有效性并阻断执行，完成从“发现威胁”到“消除威胁”的闭环。

这三个机制共同回答了开篇提出的四大风险中的关键部分：滥用防护通过持续认证、异常检测（anomaly / error detection）和实时撤销实现——任何偏离正常行为模式的步骤都会被及时发现并阻断；数据保护通过基于风险的访问实现——敏感数据始终对应最强的认证门槛。而问责制和最小权限的强化，则在前三步的基础上由自适应机制提供了动态保障：即使初始授权正确，系统仍能在运行过程中持续验证授权的持续合理性。

演讲者在 00:12:57 处强调：“each step the maturity model kind of adds a little bit more.” 自适应层级并非取代前三步，而是在其之上叠加动态能力。一个组织只有先建立了非人类身份体系、委托代理链、SIEM 日志基础、一等公民治理、临时凭证机制和细粒度上下文访问，才能真正让持续认证、风险驱动认证和实时撤销发挥作用。四步模型的价值正在于这种逐层累积的结构——每一步都是下一步的必要条件，共同构成面向智能体时代的完整 IAM 能力体系。

5 总结与延伸

5.1 风险与成熟度的闭环映射

演讲者在视频的总结部分（00:13:12）完成了一项关键工作：将开篇提出的四大核心风险与四步成熟度模型进行了系统的闭环映射。这一映射不是简单的一一对应，而是展示了安全控制如何随着成熟度提升逐步覆盖更深层次的风险敞口。

四大风险与四步模型的对应关系

- **问责制**：通过 Step 2 的非人类身份分配建立主体标识，通过 Step 3 的临时凭证缩短责任窗口，通过 Step 4 的持续认证确保每一步都可追溯。
- **最小权限**：Step 2 的委托代理机制实现了“谁代表谁”的授权链；Step 3 的细粒度上下文访问将权限从“应用级”压缩到“任务级”；Step 4 的基于风险的认证进一步根据数据敏感度动态调整权限边界。
- **滥用防护**：Step 2 的 SIEM 审计提供了事后追溯能力；Step 3 的实时检测升级为事中监测；Step 4 的实时撤销实现了事发时的即时阻断——三者构成“检测-响应”的完整闭环。
- **数据保护**：贯穿所有四步——从 Step 2 的基础访问日志，到 Step 3 的上下文感知权限，再到 Step 4 的风险驱动认证——每一层都为数据增加了一道防护。

这一映射揭示了一个深层规律：成熟度模型的每一步都是**累积式**而非**替换式**的。Foundation 不是取代 Ad Hoc，而是在其之上增加控制；Enhanced 不是取代 Foundation，而是将其三支柱升级为更精细的机制；Adaptive 同样建立在前面所有层级的能力之上。试图跳过任何一步都意味着留下结构性缺口——没有身份基础的权限控制是无效的，没有检测能力的撤销是盲目的。

5.2 渐进式实施建议

演讲者在视频结尾 (00:14:15) 给出了最核心的实施建议：不是要听众一次性做完所有事情 (“not tell you to do everything at once”)，而是先掌握全局图景 (“Here’s everything you need”)，再脚踏实地从基础开始，逐步建设。这一建议看似朴素，却直击许多组织在 AI 安全转型中的常见误区——在缺乏基础的情况下追求“最先进”的解决方案，结果往往是控制失效、团队疲惫、业务受阻。

实施路径的务实选择

基于演讲者的四步模型，我们可以进一步推导出以下渐进式实施路径：

1. **立即行动** (0-3 个月)：如果组织当前处于 Ad Hoc 状态，首要任务是为所有已部署的智能体分配非人类身份，并建立基础的 on-behalf-of 委托链。这一步不需要采购新系统，只需在现有 IAM 流程中增加对智能体的覆盖。
2. **短期目标** (3-6 个月)：部署或配置 SIEM 系统以收集智能体行为日志，建立最低限度的可审计性。同时梳理智能体的权限清单，识别并缩减过度授权。
3. **中期目标** (6-12 个月)：将智能体纳入身份治理系统，实施临时凭证机制，逐步替换长期有效的 API 密钥。引入基于任务上下文的动态权限评估。
4. **长期目标** (12-24 个月)：建立基于风险的持续认证体系，部署实时检测与自动撤销能力，实现真正的自适应安全。

5.3 核心认知转变

将演讲者的核心观点进一步延伸，我们可以这样理解智能体与组织的关系：**智能体不是“有 API key 的应用”，而是需要全生命周期治理的“数字员工”**。

传统 IAM 将 API 密钥视为应用与系统之间的连接凭证——只要密钥有效，连接就成立。这种视角适用于确定性系统，因为应用的行为是预先编码的、可预测的。但智能体不同：它会在运行时时刻做出决策、选择工具、访问数据，其行为边界不是在开发时确定的，而是在每次执行时动态展开的。

将智能体视为“数字员工”意味着：

- 它需要**入职**（创建身份并经过审批流程），而非简单地分配一个密钥；
- 它需要**岗位描述**（明确的权限范围和职责边界），而非“需要时再去申请”；
- 它需要**绩效考核**（定期的访问复核和行为审计），而非“部署后就遗忘”；
- 它需要**离职交接**（权限回收和身份注销），而非“密钥过期自动失效”。

这一认知转变是成熟度提升的根本驱动力。技术控制（临时凭证、持续认证、实时撤销）只有在“智能体是员工”这一认知前提下才有意义——你不会给人类员工一个永不过期的万能钥匙，你也不应该给智能体一个长期有效的 API 密钥。

5.4 延伸思考

演讲者的四步模型为 AI 智能体的 IAM 治理提供了一个清晰的评估框架，但在实际落地中仍有一些值得深入探讨的开放问题：

- **多智能体协作的问责链：**当多个智能体以链式或图式结构协作完成复杂任务时，“on-behalf-of”的委托链如何递归扩展？每个中间智能体既是下游的委托方，又是上游的受托方，这种双重身份如何审计？
- **模型提供商与租户的责任边界：**当组织使用第三方模型服务（如 OpenAI、Anthropic 的 API）构建智能体时，模型层面的行为（如幻觉、越狱）与应用层面的 IAM 控制之间的责任边界在哪里？
- **法规演进与合规压力：**随着欧盟 AI 法案等监管框架的落地，智能体的问责制和可解释性要求将越来越严格。四步模型中的哪一步与哪些法规要求直接对应？
- **性能与安全的权衡：**持续认证和基于风险的动态授权必然增加每次智能体调用的延迟。在高并发场景下，这种开销是否可接受？是否存在缓存或预授权的优化空间？

这些问题没有标准答案，但它们构成了从“理解模型”到“实施治理”之间的关键桥梁。演讲者的四步模型为我们提供了起点——知道“当前在哪里”和“下一步去哪里”。而如何跨越每一步之间的鸿沟，将是每个组织在 AI 时代的独特功课。

在 AI 智能体日益成为企业核心生产力的今天，IAM 不再是后台基础设施，而是决定系统能否安全、可信、可持续运行的战略能力。从 Ad Hoc 到 Adaptive 的旅程，本质上是一个组织将 AI 从“实验项目”升级为“生产级能力”的安全成熟过程。这一步，没有捷径。